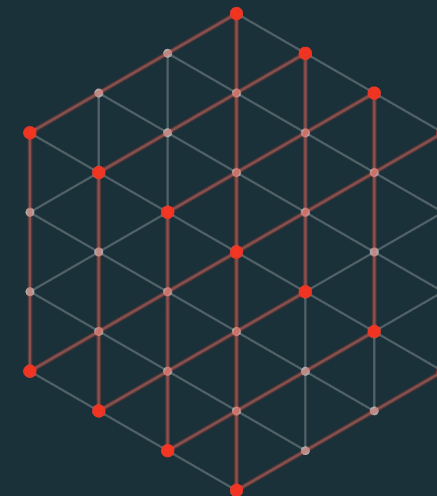


Genie security threat model

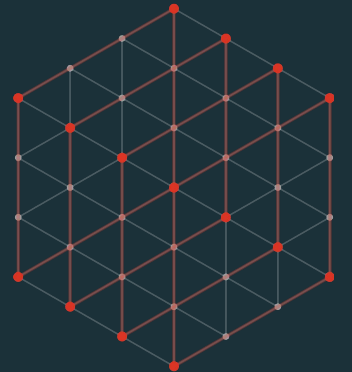
The threats that come up in customer conversations, how each is bounded, and the platform controls and AI commitments that mitigate it.

Jul 2026



Overview & foundations

What Genie is, the platform architecture and controls it inherits, the AI-specific commitments, and how to read this threat model.



OVERVIEW

Every Genie answer is grounded in your data and governed by Unity Catalog

Genie is the Databricks AI experience for users. It gives everyone in your organization a single place to ask data questions in natural language, explore AI/BI dashboards, and run Databricks Apps. Security-conscious customers want to understand the threat models that apply to platforms like Databricks, and the controls they can use to mitigate specific risks. This document states a common question for each threat, assesses it directly, rates the residual risk, and maps the controls that mitigate it.



Natural-language access

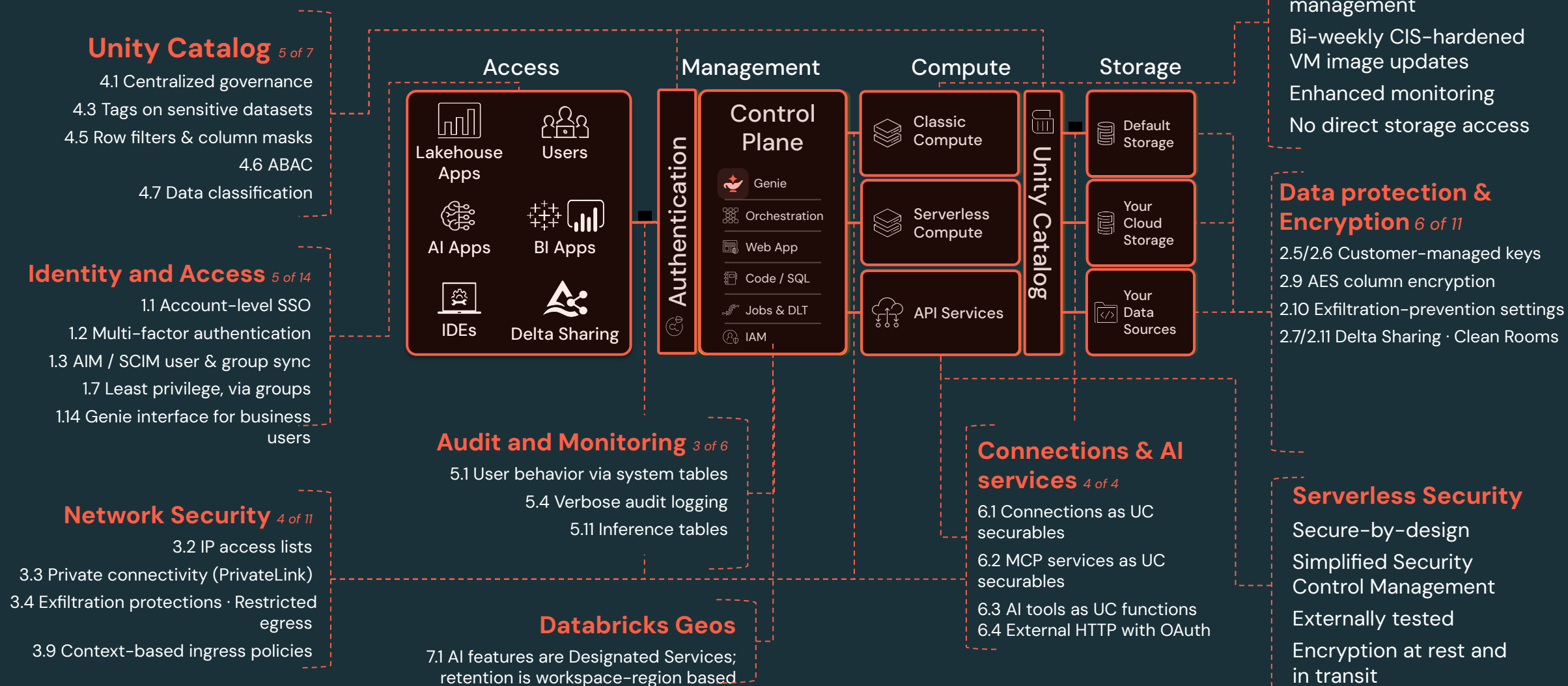
Ask questions, explore dashboards, and run apps — no SQL required.



Governed end to end

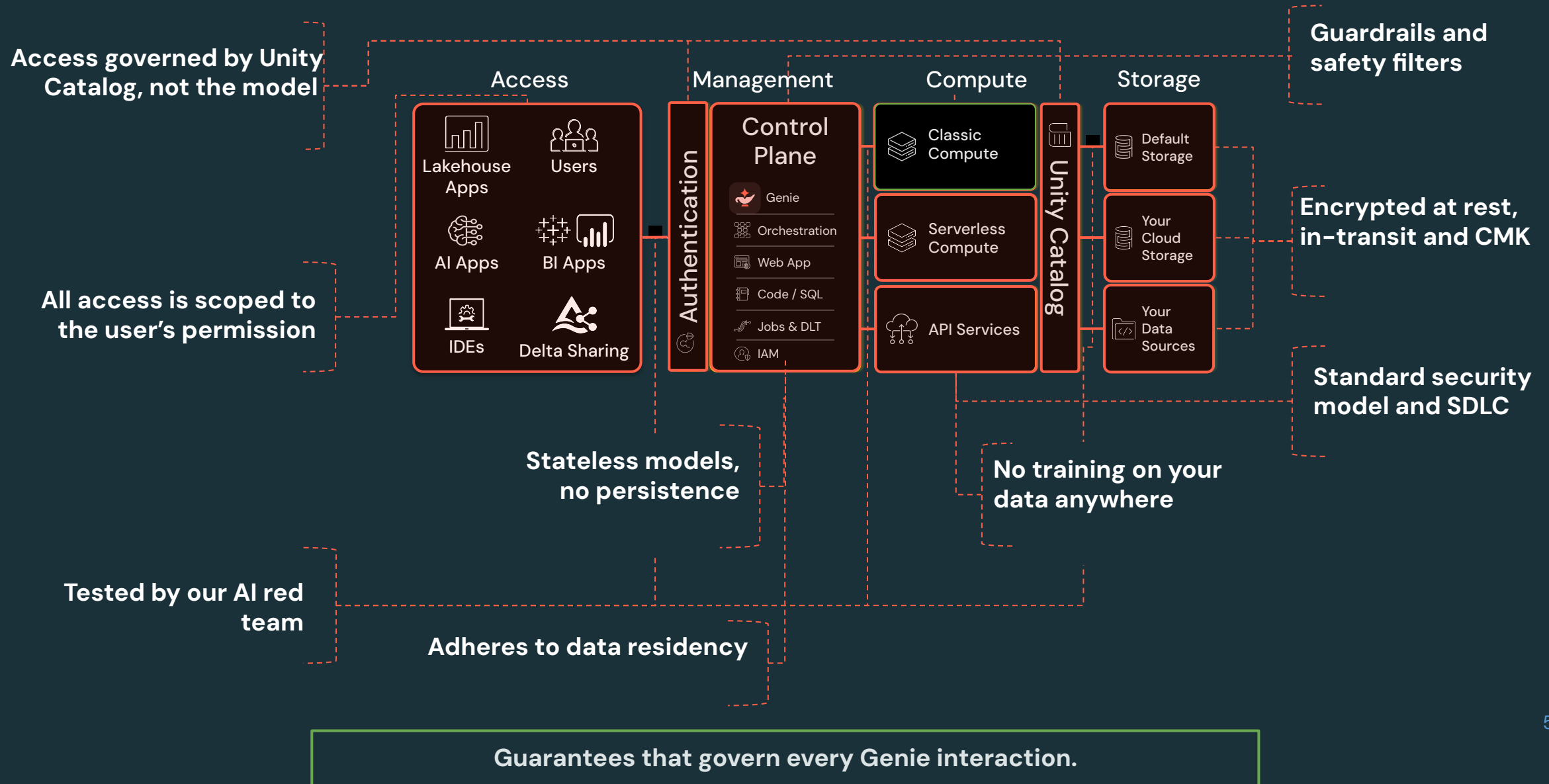
One Unity Catalog permission model, enforced on every interaction.

Databricks Overall Security Architecture



Genie runs entirely inside this architecture – it inherits every control.

Additional Security Controls in Genie



FOUNDATIONS

Shared design principles

Genie reuses existing platform components, so one uniform security model applies across features.

On-behalf-of execution

Genie runs every query on a SQL warehouse under the calling user's identity. It has no elevated identity of its own.

Unity Catalog governance

The same privileges, row filters, and column masks apply as to a handwritten query. Data the user can't access is never sent to the model.

Speed, not scope

Genie changes how fast a user discovers or acts on data they can already access — it does not expand what they can access.

Model services are stateless · no training · zero retention

Models are stateless. Databricks and its partners do not train on your data; inference runs on zero-data-retention endpoints.

Deterministic controls

Defense-in-depth layers of deterministic platform controls are un-bypassable and have no dependence on model behavior.

Shared responsibility

Databricks enforces the platform boundary; the customer owns identity, least-privilege, network, and downstream data handling.

GENIE-SPECIFIC CONTROLS

Controls that apply specifically to Genie

Beyond the inherited platform controls, these govern how Genie itself executes, is accessed, and is bounded.

On-behalf-of execution

Every query runs on a SQL warehouse under the calling user's identity — Genie has no elevated identity of its own.

Genie UI as least privilege

Gives business users governed, natural-language access without broad warehouse or notebook privileges.

Masking before the model

Row filters and column masks are applied first, so masked or filtered values never enter a prompt.

Restricted to the Agent's data scope

A Genie Space is a permissioned object scoped to a specific set of tables and a configured warehouse. Genie draws only on the tables the author added to the Space

SQL warehouse guardrails

Statement limits and query timeouts bound what any Genie-generated query can consume.

Tools & connectors as securables

MCP servers, UC functions, and external HTTP are permissioned and audited; AI Gateway centralizes monitoring.

AI-specific commitments that govern every Genie interaction

- | | | | | | |
|-----|--|-----|---|-----|--|
| 1.0 | Stateless models — the LLM stores no data between requests. | 2.0 | No training on your data — via zero-data-retention endpoints. | 3.0 | Governed by Unity Catalog — one permission model, end to end. |
| 4.0 | Access scoped to the user — only data the user can already access. | 5.0 | Encrypted everywhere — AES-256 at rest, TLS 1.2+, CMK available. | 6.0 | SDLC & tenant isolation — same production controls as the platform. |
| 7.0 | Data residency — Designated Service; retention is workspace-region based. | 8.0 | Protection from harmful output — Azure OpenAI content filtering ; Anthropic safety mechanisms. | 9.0 | Tested by our AI red team — written report available under NDA. |

HOW TO READ THIS THREAT MODEL

Each threat is assessed the same way, then mitigated by two layers of control

PER-THREAT TEMPLATE

- 01 Customer question**
The concern as customers actually raise it.
- 02 Risk assessment**
A direct, one-shot answer to the threat.
- 03 Probability**
Likelihood, impact, and residual risk when properly configured.
- 04 Controls + blast radius**
What mitigates it, and why the exposure is contained.

Platform-inherited controls

Capabilities the **customer** configures — identity, Unity Catalog, network, audit, encryption, connections, residency. Applying them is what drives residual risk down.

AI-specific commitments

Guarantees **Databricks** enforces for every Genie interaction — UC governance, user-scoped access, stateless models, no training, encryption, residency, red-teaming.

THE LANDSCAPE

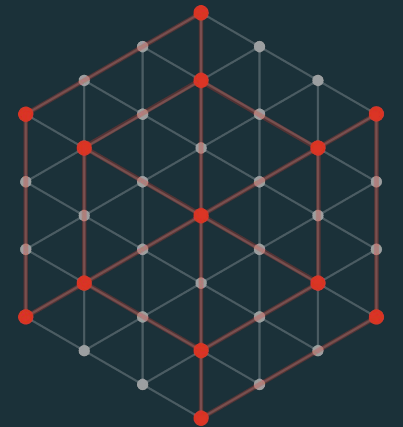
Six primary threats, plus an appendix on answer trust

- 1 Unauthorized access by compromise of over-permissioned users**
Does Genie give an attacker a faster way to find data? · Residual: **Low**
- 2 Sensitive data disclosure via Model Providers**
What data goes to the model, where, and who can see retained data? · Residual: **Low**
- 3 Prompt injection, jailbreaks, or malicious retrieved content**
Can hostile content make Genie ignore instructions or leak data? · Residual: **Low**
- 4 External connector and shadow-AI risk**
Can users quietly wire sources into AI unseen? · Residual: **Low**
- 5 Static sharing and downstream disclosure of results**
If someone shares an answer, is the viewer's permission rechecked? · Residual: **Low** (governed sharing)
- 6 AI supply chain, model routing, and content integrity**
Can I trust the models, routing, and provenance behind Genie? · Residual: **Low**

Appendix · Can I trust the Genie answer? Accuracy, hallucination, and overreliance — treated as product quality, second tier.

THREAT 01

Unauthorized access by compromise of over-permissioned users



Threat 01 · Unauthorized access by compromise of over-permissioned users

CONCERN

Does Genie give an attacker a faster way to find data if an account is compromised?

RISK DESCRIPTION

Managed AI features can make it easier for a user to find, summarize, query, or act on information they can already access. If the account is compromised or over-permissioned, AI can accelerate discovery of accessible data.

LIKELIHOOD

Moderate

IMPACT

Moderate

RESIDUAL RISK

Low

RISK ASSESSMENT

Bounded to the compromised identity's own entitlements — no privilege escalation, no cross-tenant reach. The fix is right-sizing entitlements and perimeter security, not withholding Genie.

Threat 01 · Unauthorized access by compromise of over-permissioned users

Access governed by UC, not the model

- 4.1 Centralise governance with UC
- 4.5 Row filters & column masks
- 4.6 ABAC
- +1 more

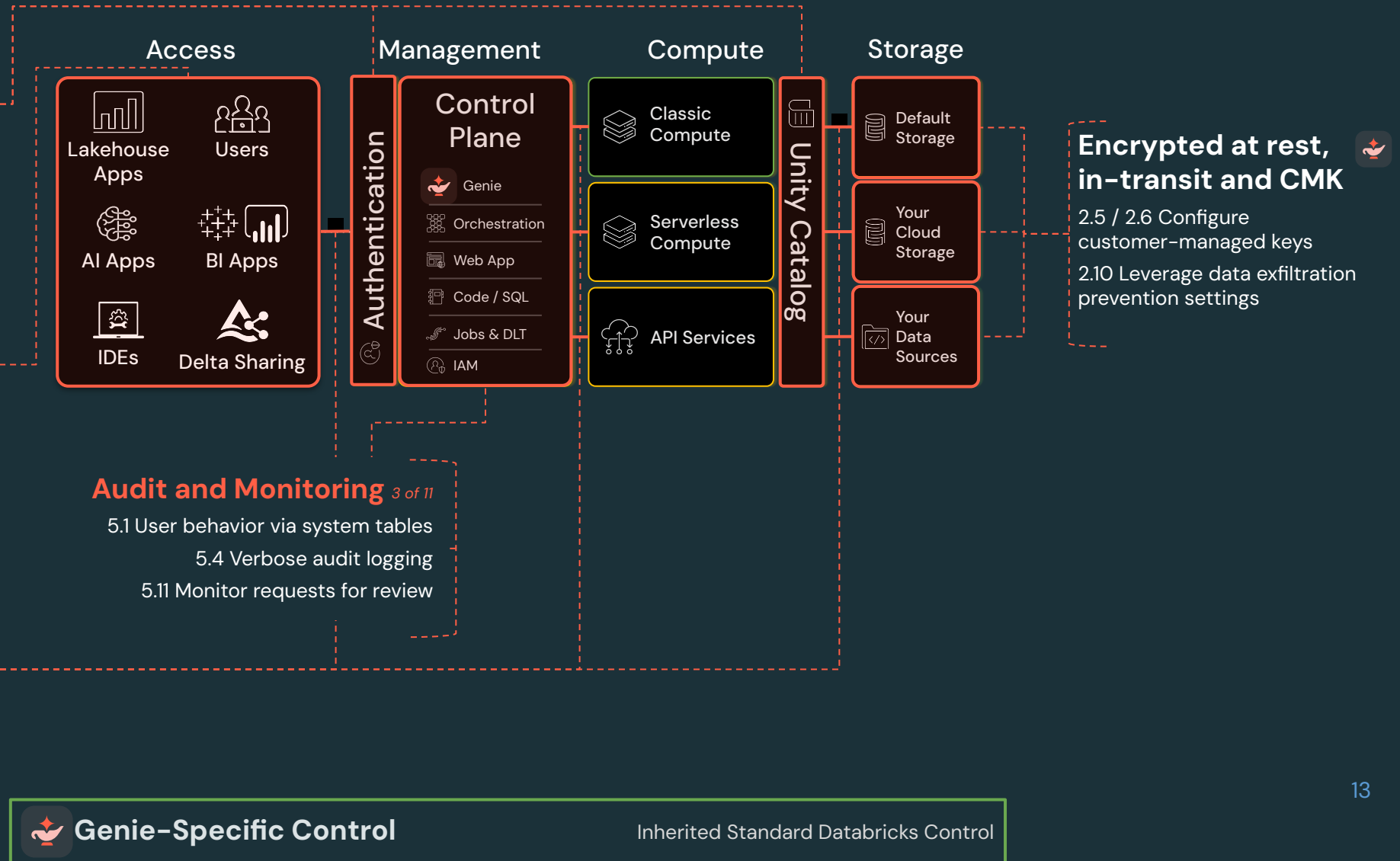
All access is scoped to the user's permission

- 1.1/1.2 SSO & MFA
- 1.7 Least privilege, via groups
- +3 more

Tested by our AI red team

Network Security

- 3.2/3.3 IP access lists or PL
- 3.4 Exfiltration protections
- 3.9 Context-based ingress policies



Least-privilege and perimeter controls move this threat from Moderate to Low

Identity & access

- 1.1/1.2 SSO at the account level & MFA
- 1.3 Use AIM / SCIM to sync users and groups
- 1.7 Least privilege — assign to groups
- 1.9 Enforce token management
- 1.14 Genie UI as a least-privilege control

Unity Catalog

- 4.1 Centralize data governance
- 4.5 Row filters & column masks
- 4.6 Attribute-based access (ABAC)
- 4.7 Data classification

Network security

- 3.2 IP access lists
- 3.3 Private connectivity (PrivateLink)
- 3.4 Egress / exfiltration protection
- 3.9 Context-based ingress policies

Audit & monitoring

- 5.1 User behavior via system tables
- 5.4 Verbose audit logging
- 5.11 Monitor requests for review

Data protection

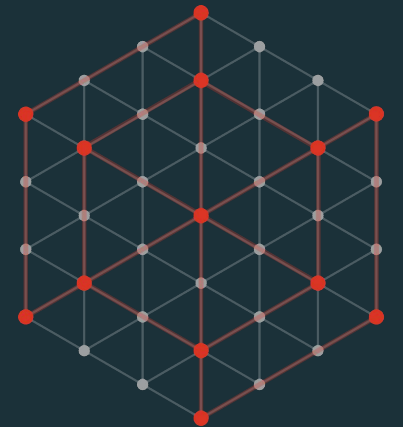
- 2.10 Exfiltration-prevention settings
- 2.5/2.6 Customer-managed keys

AI commitments

- 3.0 Governed by Unity Catalog
- 4.0 Access scoped to the user
- 1.0 Stateless models
- 2.0 No training on your data

THREAT 02

Sensitive data disclosure via Model Providers



Threat 02 · Sensitive data disclosure via Model Providers

CONCERN

Is my sensitive data going to be retained by third party model providers? Will their employees have access?

RISK DESCRIPTION

AI feature requests may include user inputs, metadata, relevant values, prior results, prompts, responses, or execution feedback. Security teams worry about model providers logs or cloud processing and legal teams worry about data being transmitted out of region and staff access.

LIKELIHOOD
HIGH

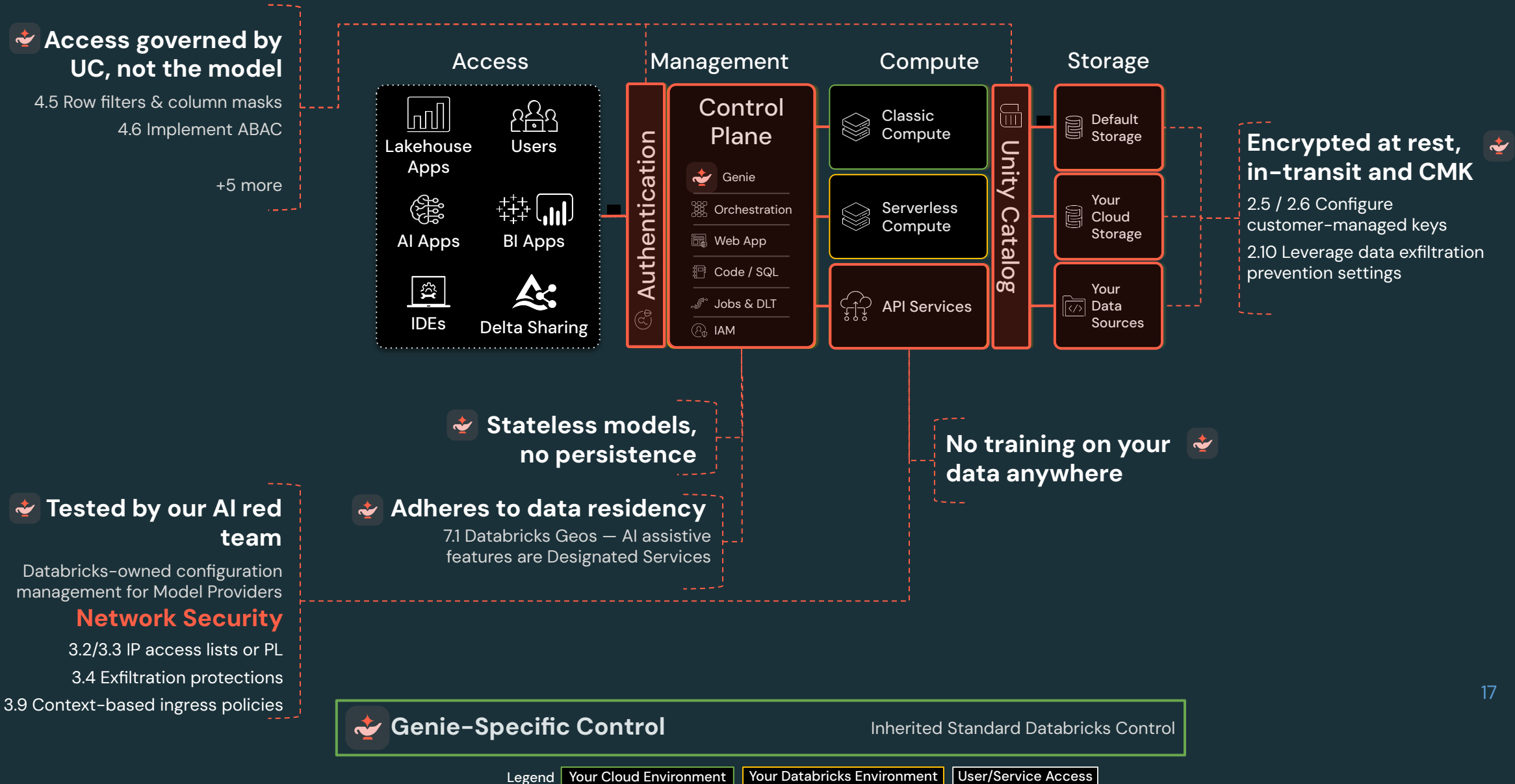
IMPACT
Moderate

RESIDUAL RISK
Low

RISK ASSESSMENT

The model providers are new third parties, but LLMs don't need to retain data. Controlling model provider geo, retention, and "no training" addresses this risk.

Threat 02 · Sensitive data disclosure via Model Providers



Encryption, governance scoping, and residency bound what leaves — and where it goes

Data protection & encryption`

- 2.5 CMK for managed services
- 2.6 CMK for storage
- 2.9 Encrypt sensitive columns (AES)
- 2.10 Exfiltration-prevention settings

Unity Catalog

- 4.5 Row filters & column masks — masked values never enter a prompt
- 4.6 Implement attribute-based access control (ABAC)
- 4.1 Centralise data governance with Unity Catalog

Network security

- 3.4 Serverless Restricted egress
- 3.3 Private connectivity
- 3.6 Serverless firewall

Data residency (Geos)

- 7.1 Databricks Geos — AI assistive features are Designated Services within residency boundaries. Retention is workspace-region based.

Audit & monitoring

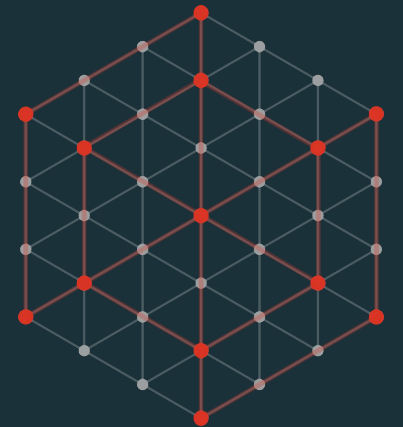
- 5.1 User behavior via system tables
- 5.4 Verbose audit logging
- 5.11 Monitor requests for review
- 5.2 Control and monitor workspace access for Databricks personnel

AI commitments

- 2.0 No training on your data
- 1.0 Stateless models
- 5.0 Encrypted everywhere, CMK
- 7.0 Data residency ·
- 6.0 SDLC

THREAT 03

Prompt injection, jailbreaks, or malicious retrieved content



Threat O3 · Prompt injection, jailbreaks, or malicious retrieved content

CUSTOMER QUESTION

Can hostile content tell Genie to ignore instructions or leak data?

RISK DESCRIPTION

A user, document, table value, notebook output, connector result, or other retrieved content may include instructions intended to manipulate the model, reveal hidden context, produce unsafe output, or steer an action.

LIKELIHOOD

Moderate

IMPACT

Low

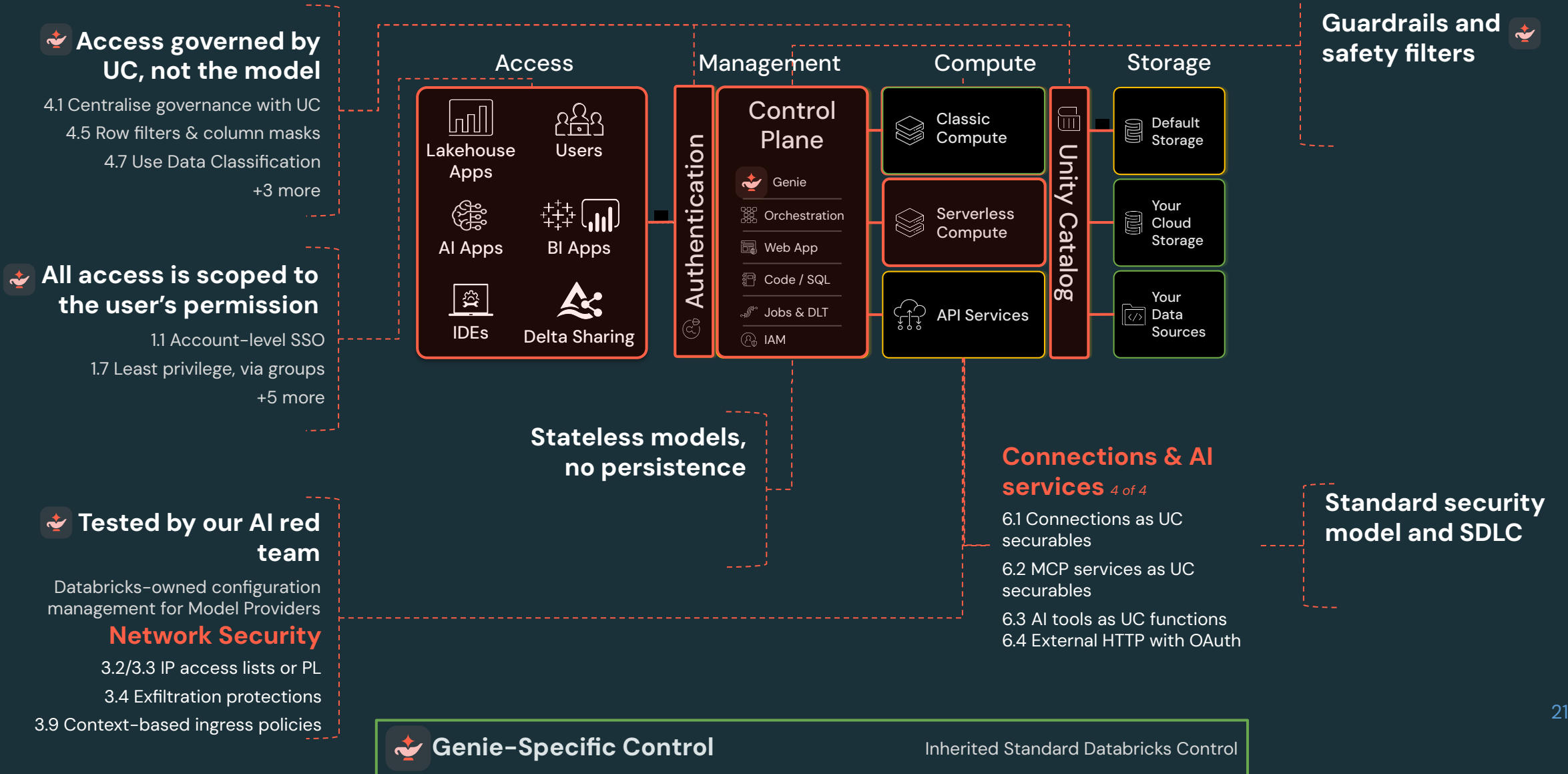
RESIDUAL RISK

Low

RISK ASSESSMENT

The input sources and instructions to Genie are in the trust boundary. The decisive control is not the model's compliance but the permission boundary. A successful injection reaches exactly what the user could reach by asking directly. Defended by model-provider content filtering plus Databricks hardening, validated by a continuous internal AI red team.

Threat O3 · Prompt injection, jailbreaks, or malicious retrieved content



Authorization is enforced outside the model — the model's compliance never grants access

Unity Catalog

- 4.5 Row filters & column masks (enforced regardless of what the model was told)
- 4.6 ABAC
- 4.7 Data classification

Identity & access

- 1.7 Least privilege caps the blast radius
- 1.11 User-isolation compute

Audit & monitoring

- 5.11 Monitor requests for review
- 5.9 Trusted / reputable sources only
- 5.4 Verbose audit logging

Network & data protection

- 3.4 Egress controls block steered exfiltration
- 2.10 Exfiltration-prevention settings

Connections & AI services

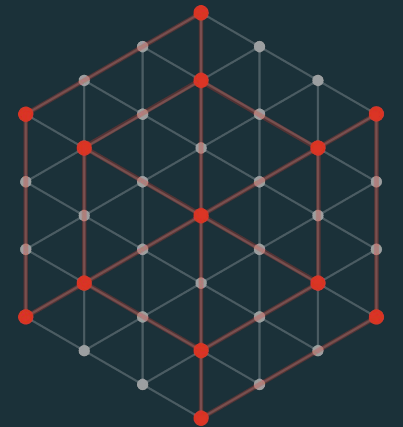
- 6.2 MCP tools as UC securables
- 6.3 AI tools as UC functions
- 6.4 External HTTP with OAuth

AI commitments

- 8.0 Protection from harmful output
- 9.0 Tested by our AI red team
- 3.0 Governed by Unity Catalog
- 4.0 Access scoped
- 1.0 Stateless

THREAT 04

External connector and shadow-AI risk



Threat 04 · External connector and shadow-AI risk

CUSTOMER QUESTION

Can users quietly wire enterprise sources into AI without the security team knowing?

RISK DESCRIPTION

AI features let users connect Genie to external systems — data sources, MCP servers, UC-function tools, and external HTTP. The "shadow AI" risk: a sensitive source or tool wired into AI without the security team's knowledge or policy, an unmonitored channel moving data out of, or context into, the governance boundary. As AI raises demand for external context, connection volume and ungoverned-connection risk grow.

LIKELIHOOD

Low *

IMPACT

Moderate

RESIDUAL RISK

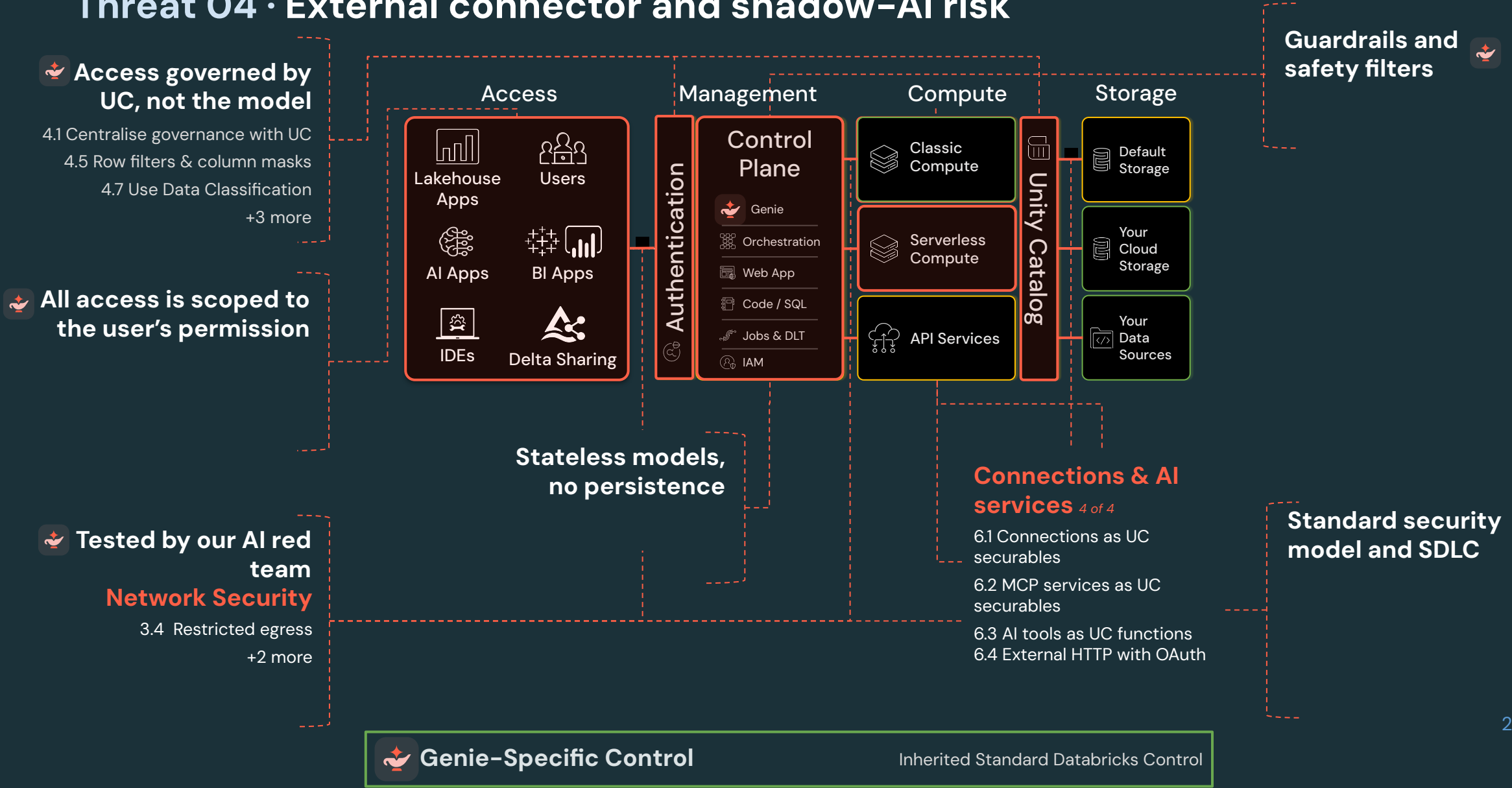
Low

RISK ASSESSMENT

Two settings decide the residual risk: who can create connections, and whether serverless egress is set to Restricted.

* Moderate where connection governance is not applied.

Threat 04 · External connector and shadow-AI risk



Connection governance plus Restricted egress leave no ungoverned path

Connections & AI services

- 6.1 Third-party connections as UC securable
- 6.2 MCP services as UC securable
- 6.3 AI tools as UC functions
- 6.4 External HTTP with managed OAuth

Identity & access

- 1.7 Restrict who can create connections
- 1.4/1.6 Limit admins
- 1.12 Governed service credentials
- 1.5 Enforce segregation of duties between administrative accounts

Network security

- 3.4 Serverless Restricted egress
- 3.6 Serverless firewall
- 3.3 Private connectivity

Audit & monitoring

- 5.1 Creation & invocation logged
- 5.11 Unity AI Gateway centralizes MCP monitoring
- 5.3 Cloud logs (CloudTrail)

Unity Catalog & data protection

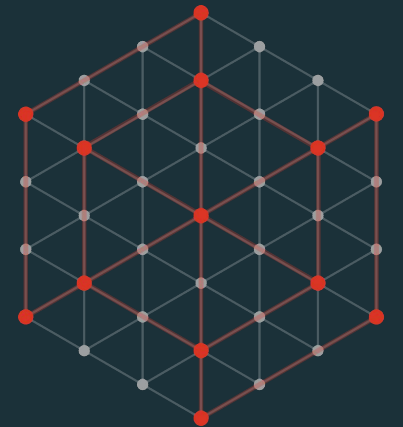
- 4.1 Central governance
- 4.3 Tag sensitive data
- 2.10 Exfiltration prevention

AI commitments

- 3.0 Governed by Unity Catalog
- 4.0 Access scoped to the user
- 6.0 SDLC & tenant isolation

THREAT 05

Static sharing and downstream disclosure of generated results



Threat 05 · Static sharing and downstream disclosure of generated results

CUSTOMER QUESTION

If a privileged user shares an answer, is the viewer's permission rechecked?

RISK DESCRIPTION

AI-generated answers, dashboard outputs, query results, screenshots, exports, embedded results, or copied text can be shared outside the original access path. Static artifacts reflect the sharer's access at creation time.

LIKELIHOOD

Low–Mod

IMPACT

Moderate

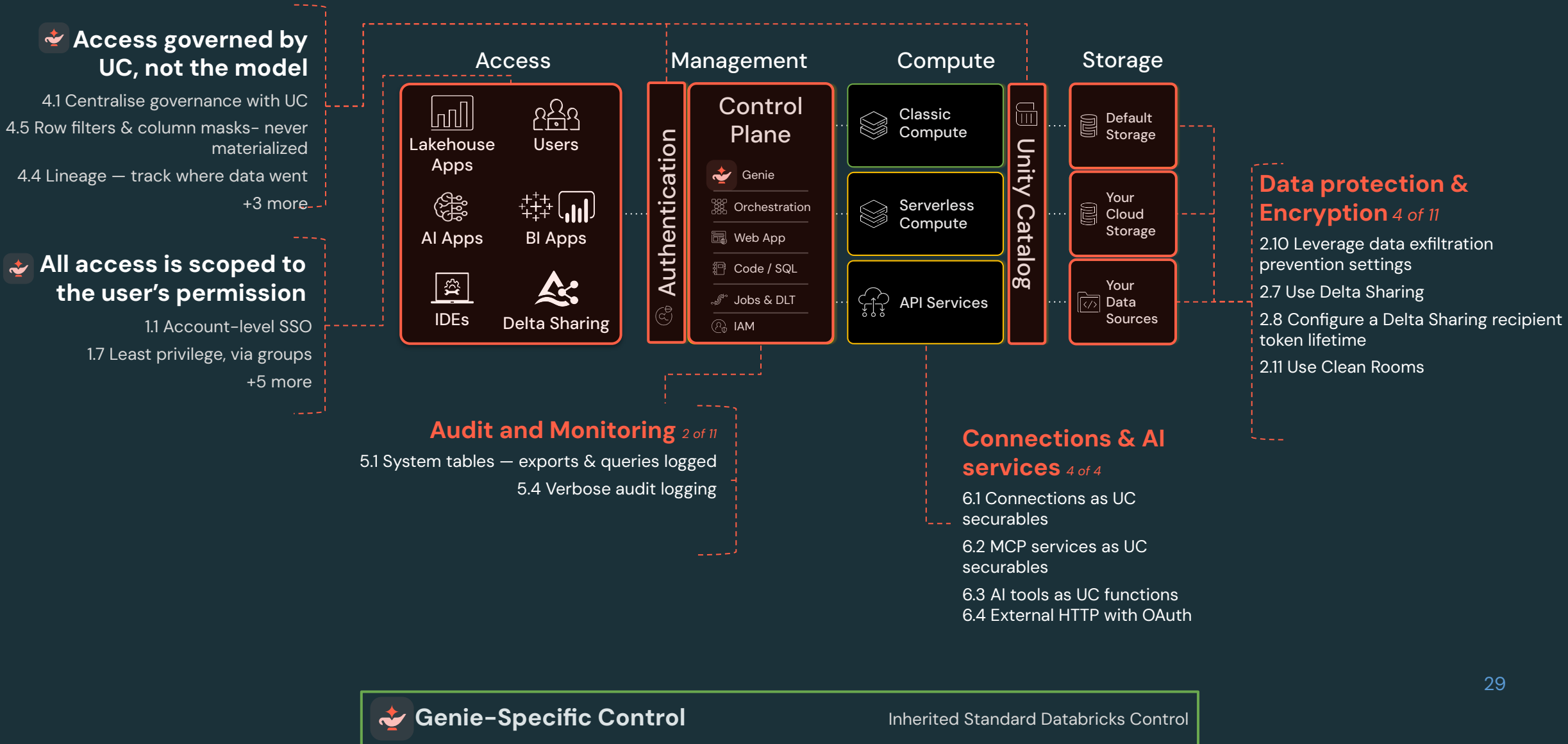
RESIDUAL RISK

Low–Mod

RISK ASSESSMENT

Recheck in force: share Genie Agents, dashboard, or table rather than an export; limit static-artifact creation with exfiltration-prevention; use governed sharing — Delta Sharing or Clean Rooms. Databricks rechecks permissions at access time for everything that stays inside the platform

Threat 05 · Static sharing and downstream disclosure of generated results



Prefer governed sharing so the per-viewer recheck stays in force

Data protection & encryption 4 of 11

- 2.10 Exfiltration-prevention — disable download, export, clipboard
- 2.7 Delta Sharing — governed downstream sharing
- 2.8 Delta Sharing recipient token lifetime
- 2.11 Clean Rooms — share insight, not a static copy

Unity Catalog 4 of 7

- 4.5 Row filters & masks — never materialized
- 4.6 ABAC
- 4.3 Tags on sensitive datasets
- 4.4 Lineage — track where data went

Audit & monitoring 2 of 11

- 5.1 System tables — exports & queries logged
- 5.4 Verbose audit logging

Identity & network

- 1.7 Least privilege — smaller export footprint
- 3.4 Egress controls bound destinations

Connections & Geos

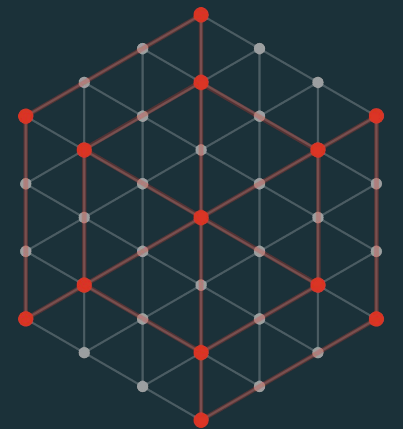
- 6.1 Onward sharing governed as a securable
- 7.1 Residency — shared data stays in region

AI commitments 3 of 9

- 4.0 Access scoped — live views rechecked per viewer
- 3.0 Governed by Unity Catalog
- 5.0 Encrypted; CMK for retained artifacts

THREAT 06

AI supply chain, model routing, and content-integrity risk



Threat 06 · AI supply chain, model routing, and content-integrity risk

CUSTOMER QUESTION

Can users choose arbitrary models, bypass approved routes, or introduce untrusted tools?

RISK DESCRIPTION

Customers may worry that a model, provider route, MCP server, or upstream data source could be manipulated or misconfigured.

LIKELIHOOD

Low *

IMPACT

Moderate

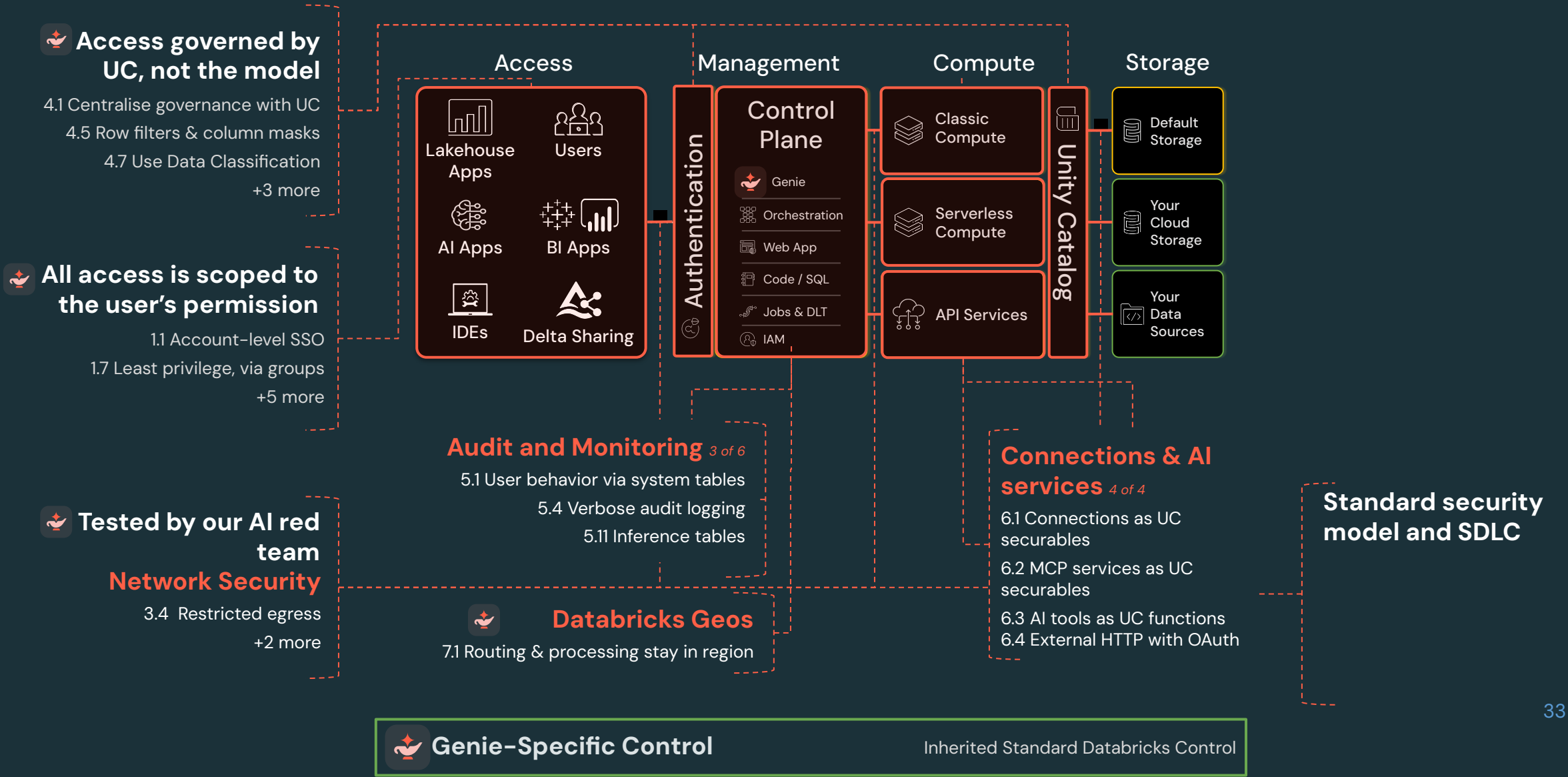
RESIDUAL RISK

Low

RISK ASSESSMENT

Hosting provider used with each Genie feature are documented on our [Databricks AI Feature Trust and Safety page](#). Every model, route, tool, and MCP server is a permissioned, audited object. Regardless of model or tool, data access stays within the user's Unity Catalog grants.

Threat O6 · AI supply chain, model routing, and content-integrity risk



UC securables govern tools & network controls guard the supply chain

Unity Catalog & network

- 4.1 Central governance ·
- 4.6 ABAC
- 3.4 Egress controls ·
- 3.3 PrivateLink
- 2.10 Exfiltration-prevention settings

Connections & AI services 4 of 4

- 6.2 MCP services as UC securables
- 6.3 AI tools as UC functions
- 6.1 Third-party connections as securables
- 6.4 External HTTP with managed OAuth

Identity & access 3 of 14

- 1.7 Restrict who can register models / routes
- 1.4/1.6 Limit admins
- 1.10 Service principals for production config

Audit & monitoring 4 of 11

- 5.11 Monitor requests for review
- 5.9 Trusted / reputable sources; scan untrusted models
- 5.8 Control library installation (allowlists)
- 5.10 Data Quality Monitoring — poisoning & drift

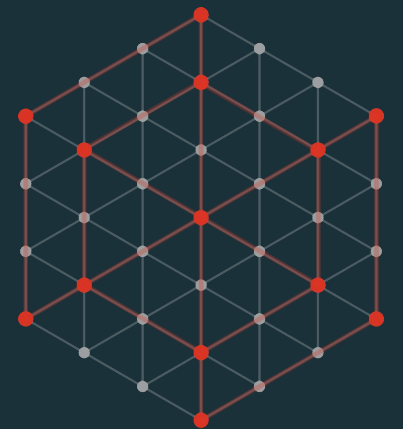
Databricks Geos

- 7.1 Routing & processing stay in region

AI commitments 5 of 9

- 9.0 Red team feeds model onboarding
- 6.0 SDLC & tenant isolation
- 8.0 Protection from harmful output
- 1.0/2.0 Stateless · no training ·
- 3.0/4.0 UC-scoped

Can I trust the answer? (accuracy, hallucination, and overreliance)



Threat 07 · Can I trust the Genie answer? (accuracy, hallucination, and overreliance)

CUSTOMER QUESTION

Can I trust Genie's answer — could it hallucinate, and can I verify how it was produced?

RISK DESCRIPTION

Large language models can produce plausible but incorrect output. A natural-language-to-SQL assistant may misinterpret a question, generate SQL that computes the wrong thing, or summarize results inaccurately – and a user may act on a wrong answer without verifying it.

LIKELIHOOD

Moderate

IMPACT

Variable

RESIDUAL RISK

Low–Mod

RISK ASSESSMENT

A wrong answer is a quality issue, not a disclosure — the data behind it is correctly scoped and the query is inspectable, so errors are catchable before they are trusted. Accuracy improves as models and curation mature.

Curation, transparency, and evaluation make answers verifiable

Genie accuracy & trust

- 8.1/8.2 Annotated metadata & knowledge store
- 8.5/8.6 Example queries & instructions
- 8.8 Certified trusted assets (verified answers)
- 8.9 Inspect the generated SQL
- 8.10 Benchmark accuracy over time

Unity Catalog

- 4.7 Data classification
- 4.4 Lineage — trace the data behind an answer
- 4.3 Tags on trusted datasets
- 4.1 Centralize governance

Audit & monitoring

- 5.11 Monitor requests for review
- 5.1 System tables

Genie accuracy & trust (cont.)

- 8.3 Define join relationships
- 8.4 SQL expressions for business metrics
- 8.7 Scope the space & pre-join with views
- 8.11 Monitor usage & act on feedback

Design principle

- Grounded, not generated — answers computed from your governed SQL
- Human-in-the-loop verification of the shown query

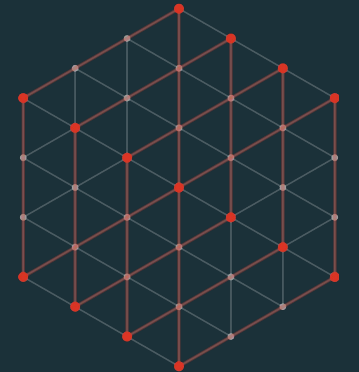
AI commitments

- 9.0 Tested by our AI red team
- 8.0 Protection from harmful output
- 3.0 Governed by Unity Catalog

APPENDIX

Reference — full control catalog

The complete Core platform controls catalog (1.x–8.x) and the full AI-specific commitments set.



Identity & access · Data protection

Identity and Access 1.1-1.14

Manage identity and access using least privilege

- 1.1 Authenticate via single sign-on (SSO) at the account level
- 1.2 Leverage multi-factor authentication
- 1.3 Use AIM to synchronize users and groups
- 1.4 Limit the number of admin users
- 1.5 Enforce segregation of duties between administrative accounts
- 1.6 Restrict workspace admins
- 1.7 Manage access according to the principle of least privilege
- 1.8 Use OAuth token authentication
- 1.9 Enforce token management
- 1.10 Use service principals for administrative tasks and production workloads
- 1.11 Use compute that supports user isolation
- 1.12 Store and use secrets securely
- 1.13 Use a restricted cross-account IAM role
- 1.14 Simplify permission management for business users with the Genie interface

Data protection and Encryption 2.1-2.11

Protect data in transit and at rest

- 2.1 Encrypt your S3 buckets & prevent public access
- 2.2 Apply bucket policies
- 2.3 Use S3 versioning
- 2.4 Backup your S3 data
- 2.5 Configure customer-managed keys for managed services
- 2.6 Configure customer-managed keys for storage
- 2.7 Use Delta Sharing
- 2.8 Configure a Delta Sharing recipient token lifetime
- 2.9 Additionally encrypt sensitive data at rest using AES
- 2.10 Leverage data exfiltration prevention settings within the workspace
- 2.11 Use Clean Rooms to collaborate in a privacy-safe environment

Network security · Unity Catalog

Network security 3.1-3.11

Secure your network and protect endpoints

- 3.1 Use a customer-managed VPC
- 3.2 Configure IP access lists
- 3.3 Use private connectivity (PrivateLink)
- 3.4 Implement network exfiltration protections
- 3.5 Isolate sensitive workloads into different networks
- 3.6 Configure a firewall for serverless compute access
- 3.7 Restrict access to valuable codebases to trusted networks
- 3.8 Private connectivity from serverless compute to cloud resources
- 3.9 Configure context-based ingress policies
- 3.10 Connect to on-premises resources using an SSH reverse tunnel
- 3.11 Isolate sensitive workloads into different workspaces

Unity Catalog 4.1-4.7

Meet compliance and data privacy requirements

- 4.1 Centralise data governance with Unity Catalog
- 4.2 Plan your data isolation model
- 4.3 Apply tags
- 4.4 Use lineage
- 4.5 Implement fine-grained access controls (row filters & column masks)
- 4.6 Implement attribute-based access control (ABAC)
- 4.7 Use Data Classification to redact sensitive values

Audit · Connections & AI services · Geos

Audit and Monitoring 5.x

Monitor system security — 5.5–5.8, 5.10

- 5.1 Monitor user behavior via system tables
- 5.2 Control and monitor workspace access for Databricks personnel
- 5.3 Monitor system activities via AWS CloudTrail and other cloud logs
- 5.4 Enable verbose audit logging
- 5.5 Manage code versions with Git folders
- 5.6 Restrict usage to trusted code repositories
- 5.7 Provision infrastructure via infrastructure-as-code
- 5.8 Control library installation
- 5.9 Use models and data from only trusted or reputable sources
- 5.10 Use Data Quality Monitoring
- 5.11 Monitor requests for review

Connections and AI services 6.1–6.4

Govern external reach as Unity Catalog securables

- 6.1 Govern third-party data connections as a Unity Catalog securable
- 6.2 Connect to third-party tools with MCP services as a UC securable
- 6.3 Create AI tools using Unity Catalog functions
- 6.4 Connect to external HTTP services with OAuth

Databricks Geos 7.1

Data residency

- 7.1 Use Databricks Geos to manage data residency (workspace-region retention)

Genie accuracy & trust

Curate and verify each Genie space so answers stay grounded in your governed data and are trustworthy

Curate & ground 8.1-8.7

Metadata, knowledge store, joins, metrics, examples, scoping

- 8.1 Provide well-annotated table & column metadata
- 8.2 Curate the Genie knowledge store
- 8.3 Define join relationships
- 8.4 Define SQL expressions for business metrics
- 8.5 Add example SQL queries
- 8.6 Add plain-text instructions
- 8.7 Scope the space & pre-join with views

Verify & improve 8.8-8.11

Certified answers, transparency, benchmarking, feedback

- 8.8 Certify trusted assets (verified answers)
- 8.9 Inspect the generated SQL
- 8.10 Benchmark accuracy over time
- 8.11 Monitor usage & act on feedback

Enforced on every Genie interaction

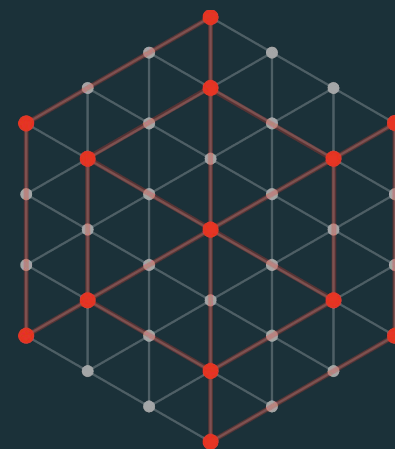
- 1.0 **Models are stateless** — the LLM stores no data between requests
- 2.0 **No training on your data** — zero-data-retention endpoints; partners do not retain data, even for abuse monitoring
- 3.0 **Governed by Unity Catalog** — one permission model, enforced end to end
- 4.0 **Access scoped to the user** — data the user cannot access is never sent to the models
- 5.0 **Encrypted everywhere** — AES-256 at rest, TLS 1.2+ in transit; customer-managed keys available
- 6.0 **SDLC and tenant isolation** — same production controls, pen testing, and internal access controls as the platform
- 7.0 **Data residency** — Designated Service; retention is workspace-region based
- 8.0 **Protection from harmful output** — Azure OpenAI content filtering; Anthropic safety mechanisms; evaluated across thousands of simulated interactions
- 9.0 **Tested by our own AI red team** — continuous testing against injection, jailbreaks, insecure code, harmful content; written report under NDA



The security boundary lives outside the model

On-behalf-of execution, Unity Catalog governance, deterministic controls, and AI commitments enforced on every interaction — so Genie accelerates your teams without expanding what anyone can reach.

 Databricks · Platform Security



Databricks Security Best Practices

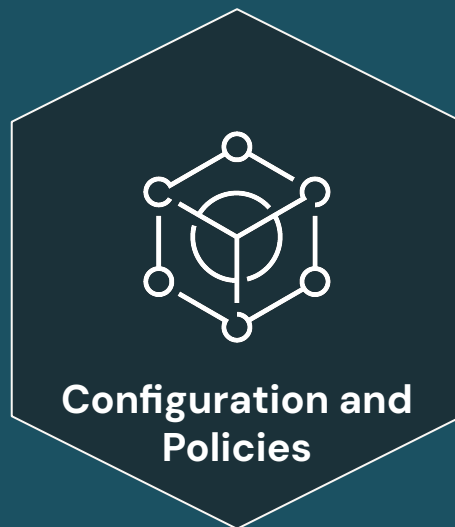
For protecting your Databricks environment.

Steps to Secure Databricks Deployments

Define Security Controls



Deploy Security Controls



Monitor Security Controls



Define Security Controls

Identify risks and controls with our Security Best Practices White Paper.

Databricks Security Architecture

Standard Best Practices

Most deployments

The following typical configurations are part of most enterprise production Databricks deployments. If you are a small data science team of a few people, you may not feel the need to deploy all of these. If Databricks may become a key part of your business or if you are analyzing sensitive data, we recommend that you review these.

- ☐ Evaluate whether [multiple workspaces](#) are required for segmentation
- ☐ Check that your [S3 buckets are encrypted and that public access is blocked](#)
- ☐ Deploy Databricks into a [customer-managed VPC](#) for increased control over the network environment. Even if you do not need this now, this option increases the chances for future success with your initial workspace
- ☐ [Authenticate via single sign-on](#)
- ☐ Use [multi-factor authentication](#)
- ☐ [Separate accounts with admin privileges](#) from day-to-day user accounts
- ☐ Configure [Databricks audit log](#) delivery

Focused Threat Models

Protect	Detect	Respond
1.13 Use service principals to run administrative tasks and production workloads so that wherever possible users do not need direct access to sensitive data 2.2 Plan your data isolation model so that sensitive data is protected by the appropriate level of isolation 2.3 Avoid storing production data in DMS 2.4 Encrypt and S3 buckets and prevent public access 2.5 Apply bucket policies to restrict access to trusted networks 2.11 Configure a Delta Sharing recipient token lifetime 2.12 Additionally encrypt sensitive data at rest using Advanced Encryption Standard (AES) 2.13 Leverage data exfiltration prevention settings within the workspace 2.14 Use Clean Rooms to collaborate in a privacy-safe environment 3.2 Configure IP access lists to protect your Delta Shares 3.5 Implement network authentication protocols to restrict outbound access to trusted destinations 3.6 Configure a firewall for serverless compute access 4.2 Isolate sensitive workloads into different workspaces 4.3 Assign Unity Catalog securables to specific workspaces to restrict access to securables that may contain sensitive data 5.0 Restrict usage to trusted code repositories so that code cannot be easily exfiltrated from the environment	5.1 Leverage system tables to identify repeated failed authentication requests, high numbers of reads and writes and changes to account and workspace settings that protect against exfiltration. Please refer to this blog for some examples 5.2 Monitor system activities via AWS CloudTrail & other logs to identify failed & suspicious assume role, data access and network access attempts	1.4 Use SCIM to manage users and groups to disable or remove accounts that are under investigation 5.3 Enable verbose audit logging so that the actions relating to potential data exfiltration attempts can be investigated

Unified Governance

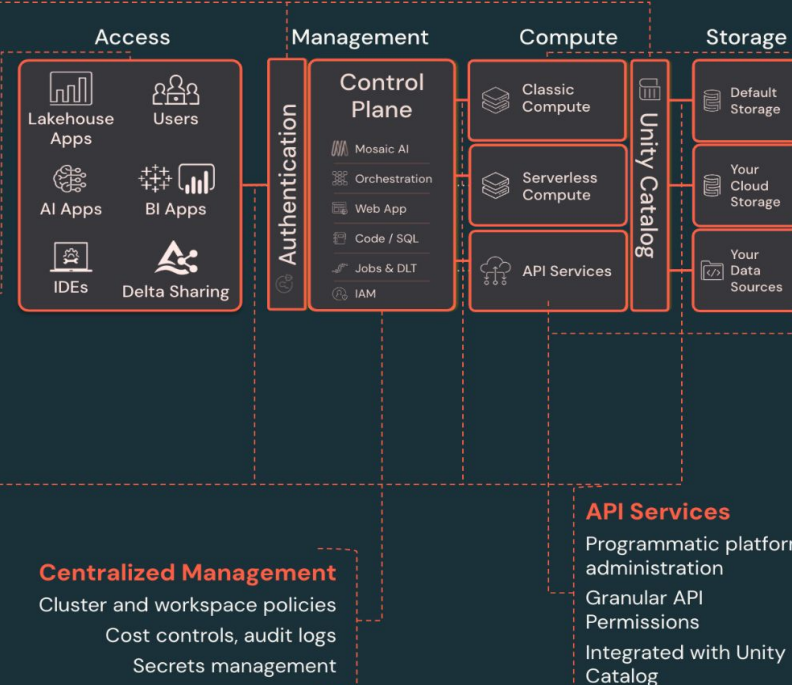
Fine-grained ACLs
RBAC & ABAC controls
Temporary down-scoped tokens

User Administration

Single sign-on
SCIM provisioning
Service principals
No local passwords

Network Security

Private Link, IP access control
Automatic host-based firewalls



Compute Security
Secure code versioning
Built-in secret management
Bi-weekly CIS-hardened VM image updates
Enhanced monitoring
No direct storage access

Data Security
Encryption in transit and at rest
Column/row-level access controls
Data governance via Unity Catalog
Data exfiltration controls
Customer-managed keys

Serverless Security
Secure-by-design
Simplified Security Control Management
Externally tested
Encryption at rest and in transit

Centralized Management
Cluster and workspace policies
Cost controls, audit logs
Secrets management

API Services
Programmatic platform administration
Granular API Permissions
Integrated with Unity Catalog

Legend Your Cloud Environment Your Databricks Environment User/Service Access

Deploy Security Controls

Deploy secure-by-design Security Reference Architecture terraform templates.

Standard Terraform Scripts

```
// EXPLANATION: The cross-account role for the Databricks workspace

// Cross Account Role
data "datacatalog_aws_assume_role_policy" "this" {
  external_id = var.databricks_account_id
}

resource "aws_iam_role" "cross_account_role" {
  name = "${var.resource_prefix}-cross-account"
  assume_role_policy = data.datacatalog_aws_assume_role_policy.this.json
  tags = {
    Name = "${var.resource_prefix}-cross-account"
    Project = var.resource_prefix
  }
}
```

Customizable For Your Org

```
// EXPLANATION: The customer-managed keys for workspace and managed storage

locals {
  cmk_admin_value = var.cmk_admin_arn == null ? "arn:aws:iam::${var.aws_account_id}:root" : var.cmk_admin_arn
}

resource "aws_kms_key" "workspace_storage" {
  description = "KMS key for databricks workspace storage"
  policy = jsonencode({
    Version : "2012-10-17",
    "Id" : "key-policy-workspace-storage",
    Statement : [
      {
        "Sid" : "Enable IAM User Permissions",
        "Effect" : "Allow",
        "Principal" : {

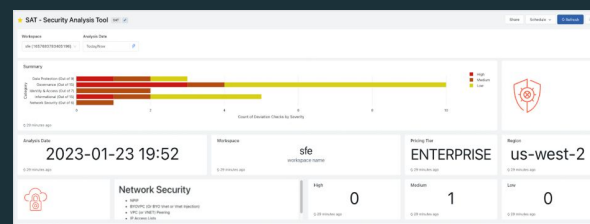
```

The screenshot displays the GitHub repository page for 'terraform-databricks-...'. The repository is public and has 40 forks and 72 stars. The main branch is selected. A merge pull request #103 is visible, submitted by metrocavich 5 days ago. The repository contains several folders: .github/workflows, aws-gov, and aws. The 'About' section describes the Security Reference Architecture (SRA) as a set of Terraform templates implementing typical security features for high-security organizations. The 'Packages' section shows no published packages. The 'Contributors' section lists 16 contributors. The 'Languages' section shows HCL at 100.0%. The 'Project Overview' section includes a diagram illustrating the SRA workflow: Security Teams use Terraform Templates to deploy Secure Workspace Deployments, which include Networking Configurations, Cloud Storage (s3, adls, gcs), Data Access Credentials, and Threat Monitoring Tools. The diagram also shows the integration with AWS, Azure, and Google Cloud.

Monitor Security Controls

Continuously monitor security posture with the Security Analysis Tool.

Security Posture Dashboards



Security Configuration Alerts

Check ID	Check	Severity	Status	Run date	Recommendation
INFO-26	Streamline the usage and management of various large language model (LLM) providers	Medium	✗	2024-06-06	Secure third-party models hosted outside of Databricks with Model Serving to streamline the usage and management of various large language model (LLM) providers such as OpenAI and Anthropic within an organization by storing API keys in one secure location.
INFO-1	Instance Profile custom tag	Low	✗	2024-06-06	Configure tagging to monitor usage and enable chargebacks.
INFO-6	Number of admin	Low	✗	2024-06-06	Limit the number of admin accounts so that most users are not admins. Note: the threshold for this SAT check can be configured.
INFO-39	Compliance security profile for the workspace	Low	✗	2024-06-06	Validate and deploy on a platform that has put in place controls to meet the unique compliance needs of highly regulated industries.
INFO-17	Compliance security profile for new workspace	Low	✗	2024-06-06	Validate and deploy on a platform that has put in place controls to meet the unique compliance needs of highly regulated industries.
INFO-6	Cluster view ACLs are set consistently	High	✓	2024-06-06	Use cluster visibility control to prevent users from viewing clusters where they do not have permissions.
INFO-11	Workspaces for supporting DB roles	High	✓	2024-06-06	It is recommended to store roles in DB roles.
INFO-4	Job view ACLs are set consistently	High	✓	2024-06-06	Use job visibility control to prevent users from viewing jobs where they do not have permissions.
INFO-10	Workspace visibility control to prevent users from viewing notebooks and other objects where they do not have	High	✓	2024-06-06	Use workspace visibility control to prevent users from viewing notebooks and other objects where they do not have

Security Best Practices



Monitors workspace configurations of an account against 60+ security checks (Azure:subscription)

Detects potential security deviations in minutes

Provides guidance & best practices

Direct links from each finding to solution documentation

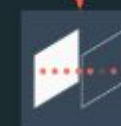
Permission Analysis



Centralized view of direct and inherited permissions across the entire account

Interactively find look up what any principal can access, or who can access any resource

Identify privilege escalation risks by finding paths from any principal to privileged roles



Secret Scanning

Scan across workspaces for hard coded secrets in notebooks and cluster configurations before they leak

Databricks AI Security Framework!

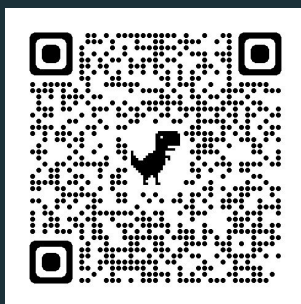
An open framework to define, deploy and monitor AI security programs.

What: Actionable recommendations on how to manage and deploy AI systems safely and securely

How: Define 13 AI system components, 62 technical risks, 64 mitigating controls, mapped to 10 industry frameworks

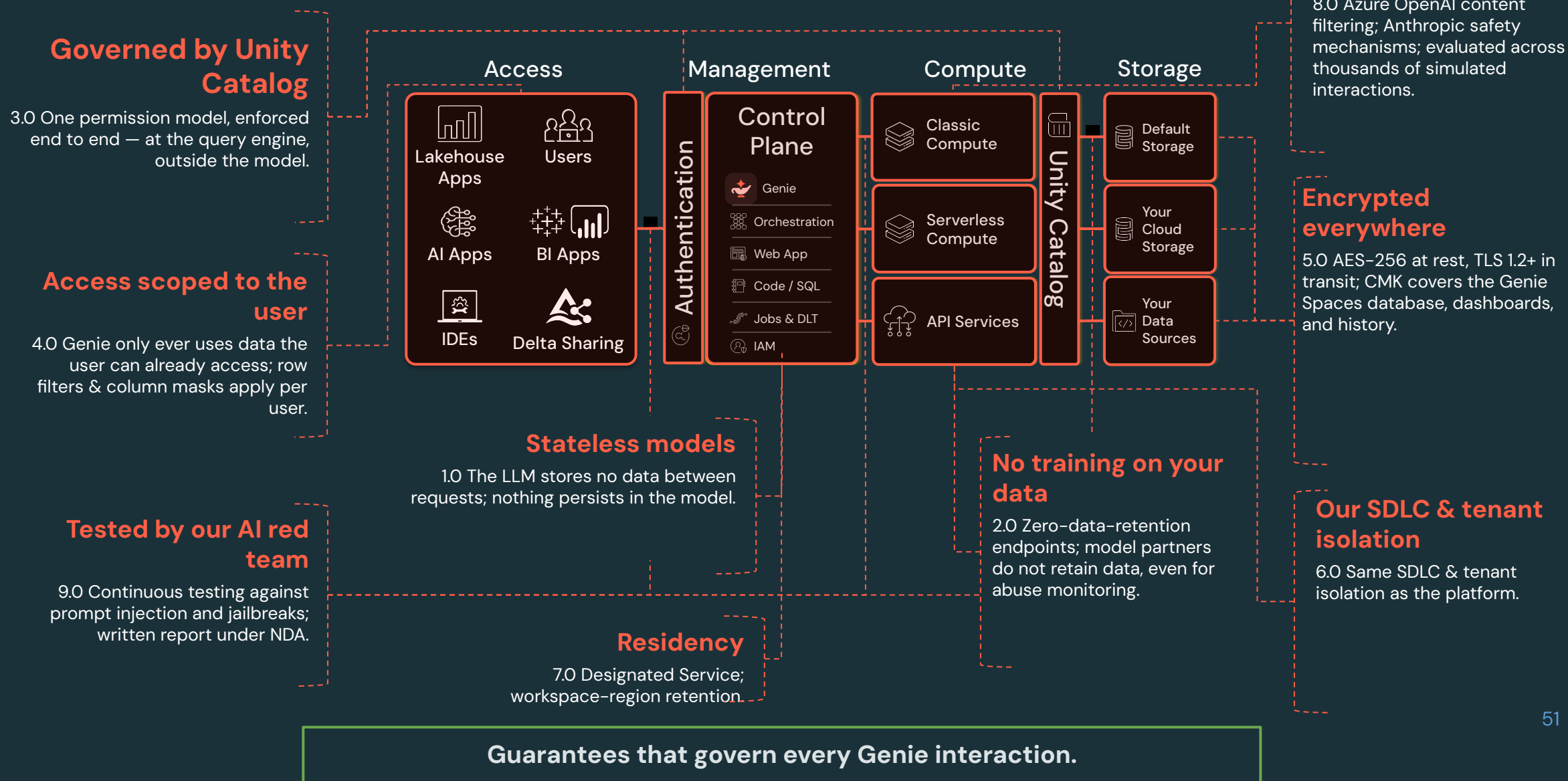
Why: Secure your AI workloads on the Databricks Data Intelligence Platform

How to get it?

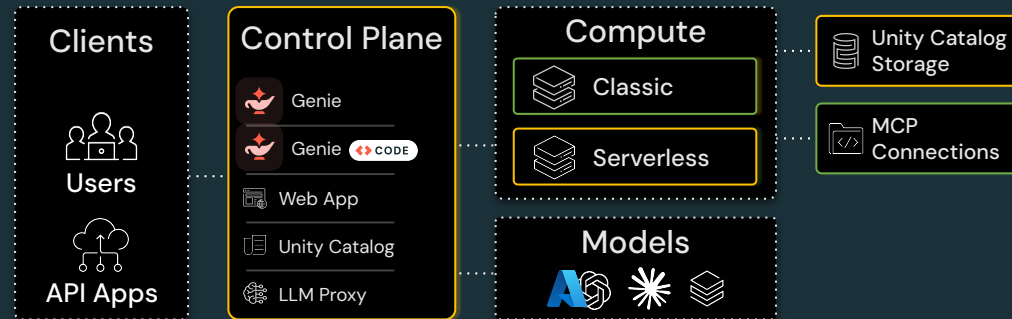


Strengthening AI security with help from industry luminaries, partners, and customers

Genie AI-Specific Commitments



Databricks Security Architecture – Genie



Genie runs entirely inside this architecture – it inherits every control.